# INCIDENT RESPONSE REPORT

**Case:** IR-2026-001 | **Incident:** Compromised FTP Service - vsftpd Backdoor | **Severity:** Critical (simulated)

**Report date:** 1 November 2026 | **Prepared for:** Final Project Assessment | **Status:** Contained and recovered (simulation)

**EVIDENCE INTEGRITY NOTICE:** This is a complete **hypothetical training case**, not a report of a real compromise or a scan performed on a live system. All hosts, private IPs, timestamps, log entries, scan snippets, hashes and response activities below are **illustrative simulations**. Public CVE/ATT&CK facts and references are real. Replace simulated evidence with your own authorized lab outputs before representing it as observed findings.

## 1. Executive Summary (3 points)

On 30 October 2026, a simulated vulnerability assessment flagged an outdated FTP service on a public-facing Linux system. Follow-up log review in the scenario showed a connection consistent with a known maliciously modified build of vsftpd 2.3.4 (CVE-2011-2523), which can expose an unauthorized shell on TCP port 6200. The attacker obtained root-level command execution on the affected server and made one attempted connection toward an internal database host. This scenario has no verified evidence of data theft, but the ability to issue privileged commands creates a high-risk exposure.

The response team isolated the FTP host, blocked affected ports, captured evidence, revoked credentials, rebuilt the host using trusted packages, and moved file exchange to SFTP. A simulated rescan and controlled functional checks found no remaining vulnerable FTP service. The incident was marked recovered after monitoring and review; a formal post-incident improvement plan remains open.

## 2. Incident Timeline (3 points)

All times simulated; Central Daylight Time (CDT, UTC-05:00), 30 October 2026 unless otherwise noted.

| Time | Phase | Event / evidence |
|---|---|---|
| 08:05 | Detection | Scheduled OpenVAS-style scan flags vsftpd 2.3.4 on ftp-gw01, TCP/21 (EV-01). |
| 08:12 | Triage | Analyst correlates service banner with CVE-2011-2523; treats version alone as a lead, not exploit proof. |
| 08:19 | Investigation | Firewall flow shows TCP/21 from 198.51.100.24 and a subsequent TCP/6200 session (EV-02). |
| 08:26 | Investigation | System telemetry shows anomalous root shell ancestry and unauthorized command activity (EV-03). |
| 08:34 | Containment | SOC blocks source 198.51.100.24, ports 21/6200, and isolates ftp-gw01 from other subnets. |
| 08:41 | Containment | Credentials used by FTP application and privileged administrators rotated/revoked; related sessions invalidated. |
| 09:00 | Evidence | Forensic image/log exports taken and hashed in the exercise case file. |
| 10:15 | Eradication | Compromised virtual machine retired; clean replacement provisioned from approved image. |
| 11:20 | Remediation | File transfer migrated to SSH/SFTP with key-based auth and restrictive firewall rules. |
| 12:05 | Validation | Illustrative follow-up scan reports ports 21/6200 closed; SSH service verified on controlled subnet (EV-05). |
| 15:30 | Recovery | Business owner approves SFTP service testing; enhanced telemetry and review begin. |
| 02 Nov, 10:00 | Lessons learned | Tabletop review assigns owners and deadlines for preventive controls. |

## 3. Systems Affected (3 points)

| Asset / IP | Role and exposure | Accounts / impact |
|---|---|---|
| ftp-gw01 / 192.168.56.105 | Linux internet-facing FTP lab server; TCP/21 vsftpd 2.3.4; unexpected TCP/6200 backdoor in scenario. | root: unauthorized command execution; ftp_svc: credential rotation; trust lost, rebuild required. |
| db-int01 / 192.168.56.120 | Internal PostgreSQL host, TCP/5432 restricted to application subnet. | db_app: no confirmed compromise; one attempted lateral connection investigated. |
| soc-mon01 / 192.168.56.10 | Security monitoring / OpenVAS scanner, authorized administrative access. | scanner_svc: detection only; no compromise observed. |
| sftp-gw02 / 192.168.56.106 | Clean replacement SFTP gateway; TCP/22 only from approved source networks. | sftp_transfer: restricted, key-based, least privilege; restored service. |

Scope assessment: one confirmed compromised host in this **simulation**; one internal database host assessed as potentially targeted but not proven compromised. The 192.168.56.0/24 addresses are private lab addresses; 198.51.100.24 is a documentation-only example IP, not an attributed malicious actor.

## 4. Root Cause Analysis (3 points)

**Primary cause:** A vulnerable, untrusted vsftpd 2.3.4 software build was allowed to run on an externally reachable FTP service. CVE-2011-2523 describes a backdoored distribution of vsftpd 2.3.4 downloaded in a specific 2011 interval, which can open a shell on TCP/6200. **Version detection by itself does not prove that a particular installed package contains the malicious modification**; package provenance and correlated behavioral evidence are necessary for that conclusion. The simulated lab explicitly assumes the backdoored build was installed.

**Contributing failures:** legacy FTP remained enabled; package authenticity was not validated; vulnerability remediation exceeded policy; inbound access was too broad; anomaly detection did not initially flag unexpected TCP/6200 activity; host-to-host egress restrictions were incomplete.

**Supporting simulated evidence:** EV-01 banner/scan finding, EV-02 inbound 6200 flow, EV-03 unexpected root shell, and EV-04 change-control record showing legacy service exception. **Public reference:** NVD rates CVE-2011-2523 critical (CVSS v3.1 9.8); attribution to a named threat group is unsupported.

## 5. Indicators of Compromise (3 points)

| Indicator | Illustrative value | Significance / confidence |
|---|---|---|
| Source IP | 198.51.100.24 | Documentation-range simulation; source of unsolicited sessions, not a real-world blacklist entry. |
| Backdoor port | 6200/tcp on 192.168.56.105 | Unexpected listener / session following FTP interaction; strong case-specific indicator. |
| Suspicious process | vsftpd child -> /bin/sh (uid=0) | Unexpected root shell ancestry in sample telemetry; strong if validated. |
| Suspicious command | id ; whoami ; uname -a | Illustrative post-access discovery commands, not independently malicious. |
| Credential/account | root privileged shell; ftp_svc rotated | Root context is impact evidence; no new account creation proven. |
| Hash evidence | Not available from authentic image | No fabricated malware SHA-256 presented as real forensic artifact. |
| Network behavior | Connection attempt ftp-gw01 -> db-int01:5432 | Potential lateral-access probe; no proof of successful authentication. |

IoC retention plan: preserve raw logs, packet captures, file-system image, package hashes and acquisition notes with UTC conversion, analyst identification, and SHA-256 checksums calculated **from actual acquired artifacts** when available.

## 6. Threat Intelligence Integration (3 points)

| ATT&CK mapping | Observed / simulated behavior | Assessment |
|---|---|---|
| T1190 - Exploit Public-Facing Application | FTP service exposed; exploitation through backdoored vsftpd service. | Initial Access; behavior aligns with technique, not an actor attribution. |
| T1059.004 - Unix Shell | Unexpected /bin/sh command interpreter in privileged context. | Execution; simulated host telemetry. |
| T1016 - System Network Configuration Discovery | Post-access environment/network inspection commands. | Discovery; low-confidence if commands observed without context. |
| T1046 - Network Service Discovery | Attempted internal database connection following compromise. | Discovery hypothesis; only a single connection is shown. |
| T1078 - Valid Accounts | No evidence attacker authenticated using legitimate credentials. | Not asserted; shown to distinguish unobserved techniques. |

Threat intelligence context: NVD and the Debian security tracker describe the historically backdoored vsftpd distribution. MITRE ATT&CK T1190 provides the public-facing service exploitation pattern. This is a **supply-chain-compromised software distribution** case pattern, not evidence of any specific modern threat actor campaign. No responsible named threat actor can be assigned from the provided indicators.

## 7. Containment Actions (3 points)

• **1 | 08:34:** Apply upstream firewall deny rules to the example source and block TCP/21 and TCP/6200 pending service restoration.

• **2 | 08:36:** Quarantine ftp-gw01 at the hypervisor/VLAN boundary; permit only approved evidence collection to prevent lateral movement.

• **3 | 08:39:** Preserve volatile data where feasible; document listening ports, running processes, active sessions, and administrative context.

• **4 | 08:41:** Disable FTP service and invalidate ftp_svc and exposed administrator secrets, SSH keys and active sessions.

• **5 | 08:48:** Hunt for 6200/tcp activity and related command execution on other servers; inspect db-int01 for suspicious logins.

• **6 | 09:00:** Transfer evidence to access-controlled storage with chain-of-custody records before destructive clean-up.

## 8. Remediation Steps (3 points)

• Remove the untrusted installation by retiring/re-imaging ftp-gw01 rather than trusting an in-place package replacement after root compromise.

• Provision sftp-gw02 from a known-good and authenticated OS image with maintained OpenSSH packages; prohibit legacy FTP and anonymous FTP.

• Restrict TCP/22 to allowlisted client networks, enforce key-based authentication, disable direct root SSH login, and limit file-system permissions.

• Rotate affected user/service credentials; review sudo rules, authorized_keys, cron/systemd persistence, startup scripts and privileged groups.

• Apply OS security updates and enable endpoint, authentication, file-integrity, and network-flow logging to centralized retention.

• Validate both network findings and business functions: repeat credentialed scan; inspect installed package signatures and service listeners; test upload/download, ownership, authentication failures and logging.

### *Before / after verification - simulated lab outputs*

| Control | Before (EV-01 / EV-02) | After (EV-05) |
|---|---|---|
| TCP/21 FTP | OPEN; vsftpd 2.3.4 banner | CLOSED / filtered; service removed |
| TCP/6200 | Unexpected connection/listener | CLOSED / filtered; no listener |
| CVE-2011-2523 scan finding | Flagged, requiring package validation | Not detected on clean SFTP build |
| TCP/22 SSH/SFTP | Legacy SSH management present | SFTP from approved subnet only |
| Root process anomaly | Unexpected shell in lab trace | None observed in 24-hour simulated monitoring |

Validation criterion: the follow-up OpenVAS/Nessus-equivalent scan must show CVE-2011-2523 absent, the insecure service removed, and no unknown 6200 listener. Passing a scan alone is **not** sufficient after confirmed root-level compromise; rebuild and forensic scope validation are also required.

## 9. Lessons Learned (2 points)

The case exposed a gap between vulnerability identification and service retirement. Legacy software exceptions lacked review deadlines; vendor provenance was not monitored; segmentation allowed excess reachability; and detection rules did not prioritize unusual service-to-shell behavior. Operationally, evidence capture should precede destructive remediation, and teams should distinguish a vulnerable banner from independently verified exploitation. The scenario also reinforced that a host with potential root compromise needs a trusted rebuild rather than only an application update.

## 10. Recommendations (2 points)

| Action / measure | Owner | Deadline / target |
|---|---|---|
| Retire all unauthenticated FTP; migrate to SFTP and block inbound 21/6200 at perimeter. | Infrastructure Lead | Within 7 days; 100% internet-exposed FTP removed. |
| Maintain signed-package provenance + critical patch SLA. | Vulnerability Manager | 30 days; critical findings triaged within 24 h, resolved within 7 days. |
| Deploy SIEM rule for FTP process spawning shell or unexpected 6200 listener. | SOC Lead | 14 days; alert test passes in <5 minutes. |
| Enforce deny-by-default east-west rules for transfer tier. | Network Security | 21 days; no unauthorized reachability to DB subnet. |
| Practice forensic acquisition and credential-rotation tabletop. | IR Manager | 45 days; two exercises/year and 100% evidence checklist completion. |
| Rescan and audit exceptions monthly; track remediation closure. | Security Governance | Monthly; >95% SLA compliance and zero unapproved exceptions. |

## 11. Appendices (2 points)

### *Appendix A. Illustrative OpenVAS-style finding (EV-01)*

```
Host: 192.168.56.105 (ftp-gw01)
Port: 21/tcp
Service banner: vsftpd 2.3.4
Finding: CVE-2011-2523 - possible backdoored vsftpd 2.3.4
Severity: Critical | CVSS v3.1: 9.8
Analyst note: Confirm package provenance; banner is insufficient proof.
```

### *Appendix B. Simulated traffic and process log (EV-02, EV-03)*

```
2026-10-30 08:19:10 -0500 ALLOW 198.51.100.24:50122 -> 192.168.56.105:21 TCP
2026-10-30 08:19:13 -0500 ALLOW 198.51.100.24:50126 -> 192.168.56.105:6200 TCP
2026-10-30 08:25:41 -0500 PROC ftp-gw01 uid=0 ppid=1421 exe=/bin/sh parent=vsftpd
2026-10-30 08:26:02 -0500 NET ftp-gw01 -> 192.168.56.120:5432 TCP SYN
```

### *Appendix C. Simulated post-remediation check (EV-05)*

```
Host: 192.168.56.106 (sftp-gw02)
21/tcp: closed | 6200/tcp: closed
22/tcp: open (restricted SFTP) | CVE-2011-2523: not found
Package origin: approved repository | Verification: simulated PASS
```

### *Appendix D. Evidence register / chain of custody*

| Evidence ID | Type and custody note | Status |
|---|---|---|
| EV-01 | Pre-remediation scan mock-up; case training attachment. | SIMULATED |
| EV-02 | Firewall traffic mock-up; source/port correlation. | SIMULATED |
| EV-03 | Process telemetry mock-up; /bin/sh ancestry. | SIMULATED |
| EV-04 | Change record noting expired FTP exception (narrative only). | SIMULATED |
| EV-05 | Post-remediation scan mock-up; SFTP verification. | SIMULATED |

Authentic lab submission would include raw exported scan reports, acquisition times, screenshots, tool versions, capture source paths, collector identities, cryptographic checksums, and custody transfers. No actual scans or screenshots were provided for this report.

### *Appendix E. Verified external references*


[1] NVD CVE-2011-2523: https://nvd.nist.gov/vuln/detail/CVE-2011-2523

[2] MITRE CVE record: https://www.cve.org/CVERecord?id=CVE-2011-2523

[3] Debian Security Tracker CVE-2011-2523: https://security-tracker.debian.org/tracker/CVE-2011-2523

[4] MITRE ATT&CK T1190: https://attack.mitre.org/techniques/T1190/

[5] MITRE ATT&CK T1059.004: https://attack.mitre.org/techniques/T1059/004/

[6] MITRE ATT&CK T1046: https://attack.mitre.org/techniques/T1046/

[7] MITRE ATT&CK T1016: https://attack.mitre.org/techniques/T1016/